KONTROL

ARQUITECTURA TÉCNICA, SEGURIDAD E INFRAESTRUCTURA

Diseño lógico, despliegue, operación, continuidad, rendimiento y protección

Volumen 5 | Versión 1.0 | Corte documental y normativo: 3 de agosto de 2026

Producto	Kontrol - Plataforma Administrativa Empresarial para Venezuela
Ámbito	Empresas privadas; multiempresa, multisucursal, multimoneda y multirrubro
Modalidad inicial	Administración, inventario, compras, ventas, tesorería y núcleo fiscal venezolano
Uso	Especificación, arquitectura, wireframes, desarrollo, QA, auditoría y homologación
Clasificación	Confidencial - documento maestro de producto

Kontrol es el nuevo nombre del producto. Las referencias históricas a INNOVA se utilizan únicamente como fuente de requerimientos y deben migrarse documentalmente.

1. Estrategia arquitectónica

Se recomienda iniciar con un monolito modular desplegable por contenedores. Los módulos conservan límites claros, contratos internos y ownership de datos, evitando la complejidad prematura de microservicios. Servicios especializados pueden extraerse cuando exista necesidad demostrada de escala, aislamiento o integración.

> **Regla de arquitectura**
>
> La separación modular debe existir en código, datos, permisos, eventos, pruebas y documentación; no basta con carpetas.

2. Componentes lógicos

Componente	Responsabilidad
Frontend web	React + TypeScript; router; TanStack Query; sistema de diseño; accesibilidad; PWA opcional.
API	FastAPI/Python; módulos de dominio; validación; autorización; transacciones; OpenAPI.
PostgreSQL	Fuente de verdad; constraints; locks; partición/índices; auditoría y pgaudit/equivalente.
Workers	Generación de documentos, reportes, correo, conciliación, importaciones y tareas programadas.
Cola	Mensajería durable para trabajos y eventos; reintentos y dead-letter.
Documentos	Almacenamiento de objetos; metadatos, hash, antivirus, cifrado y retención.
Cache	Sesiones, catálogos y consultas seguras; nunca fuente de verdad fiscal.
Observabilidad	Logs, métricas, trazas, alertas, dashboards y seguimiento de Request ID.
Gateway/Nginx	TLS, límites, compresión, headers, proxy y archivos estáticos.
Integraciones	BCV, correo, bancos, dispositivos e interfaces oficiales autorizadas.

3. Módulos de backend

Módulo	Límite
organization	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
identity_access	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
master_data	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
catalog	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
pricing	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
inventory	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
procurement	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
sales	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
receivables	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
payables	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
treasury	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
fiscal	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
regulatory	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
approvals	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.

Módulo	Límite
reporting	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
audit	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
documents	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
notifications	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.
integrations	Modelos, servicios, repositorios, endpoints, eventos y pruebas del dominio.

4. Seguridad

Área	Controles
Identidad	Contraseñas robustas, MFA, recuperación segura, bloqueo, rotación y sesiones visibles.
Autorización	RBAC + alcance + condiciones; deny by default; backend como autoridad.
Segregación	Reglas SoD y maker-checker para pagos, reglas, notas, ajustes y excepciones.
Datos	TLS, cifrado en reposo, secretos fuera del código, backups cifrados.
Aplicación	OWASP ASVS, validación, CSRF según modelo, XSS, SSRF, inyección, file upload y rate limits.
API	Scopes, expiración, idempotencia, firma de webhooks, límites y auditoría.
Base de datos	Roles separados, no superusuario en app, RLS/controles, pgaudit, bloqueo DDL productivo.
Documentos	Antivirus, MIME real, hash, URLs firmadas, expiración y autorización por objeto.
Administración	Acceso privilegiado temporal, justificado, aprobado y registrado.
Incidentes	Detección, triage, contención, evidencia, notificación, recuperación y postmortem.

5. Multiempresa y aislamiento

- Tenant y company explícitos en cada agregado.
- Filtros de seguridad aplicados en repositorios y consultas.
- Pruebas negativas para acceso cruzado.
- Archivos y claves de almacenamiento segmentados.
- Caché y colas incluyen tenant/company en la clave.
- Reportes y exportaciones verifican alcance antes de ejecutar y descargar.
- Soporte no accede a datos sin sesión privilegiada autorizada.

6. Transacciones, concurrencia e idempotencia

Operación	Control
Emitir factura	Transacción única: validar, asignar serie/control, persistir snapshot, movimientos/eventos y commit.
Aplicar pago	Lock de saldos; validar disponibilidad; crear aplicaciones; recalcular; commit.
Reservar inventario	Lock por producto/almacén/lote; impedir sobre-reserva salvo política.
Recibir serial	Restricción unique y transacción por recepción.
Crear comprobante	Idempotency key por evento y proveedor/período/documentos.
Procesar webhooks	Firma, deduplicación, orden y replay seguro.
Jobs	At-least-once con handlers idempotentes y estado de ejecución.

7. Rendimiento y capacidad

Área	Estrategia
Catálogos	Índices por empresa, estado, código, nombre normalizado, barcode y atributos buscables.
Documentos	Paginación server-side; filtros selectivos; proyecciones de lectura.
Inventario	Ledger + proyecciones; reconciliación periódica; no sumar toda la historia en cada pantalla.
Reportes	Asíncronos para grandes volúmenes; snapshot de parámetros y archivo descargable.
Auditoría	Partición por fecha/tenant, almacenamiento inmutable y búsqueda indexada.
Archivos	Object storage y CDN/URLs firmadas; no BLOB masivo en tablas transaccionales.
Pruebas	Carga, estrés, soak, concurrencia y volumen con datos representativos.

8. Infraestructura por ambientes

Ambiente	Propósito
Local	Docker Compose, datos sintéticos, hot reload, correo falso, secretos locales.
Development	Integración continua, migraciones automáticas controladas y datos de prueba.
QA	Configuración similar a producción; suites E2E, seguridad y rendimiento.
UAT	Usuarios de negocio, datos anonimizados/sintéticos, versiones candidatas.
Staging fiscal	Prueba de versión fiscal, impresión, documentos, control y regresión.
Producción	Alta disponibilidad según SLA, backups, monitoreo, soporte y change management.
DR	Ambiente recuperable, runbooks y pruebas periódicas.

9. CI/CD y liberación

1. Lint, formato y análisis estático.
2. Pruebas unitarias frontend/backend.
3. Pruebas de contrato y migraciones.
4. Construcción de imágenes reproducibles y SBOM.
5. Análisis de vulnerabilidades y dependencias.
6. Pruebas de integración y E2E.
7. Firma y publicación de artefactos.
8. Despliegue a QA/UAT con aprobación.
9. Pruebas smoke y rollback.
10. Liberación productiva por ventana y monitoreo.

10. Base de datos y migraciones

- Alembic o equivalente; toda migración revisada y reversible cuando sea posible.
- Expand/contract para cambios compatibles.
- Backfill por lotes y validación de conteos.
- No ejecutar DDL riesgoso sin plan de bloqueo y ventana.
- Migraciones fiscales requieren versión y evidencia de homologación cuando afecten emisión.
- Datos semilla idempotentes y separados de datos legales configurables.

11. Respaldo, continuidad y recuperación

Control	Definición
RPO	Objetivo inicial ≤15 minutos para datos transaccionales; ajustar por infraestructura.
RTO	Objetivo inicial ≤4 horas; funciones fiscales críticas requieren plan específico.
Backups	Full + incrementales/WAL, cifrados, retenidos y separados.
Restore	Prueba mensual automatizada y ejercicio integral trimestral.
Documentos	Replicación/versionado y verificación de hash.
Contingencia fiscal	Procedimiento aprobado, plantillas, sincronización posterior y auditoría.
Runbooks	Caída DB, pérdida de nodo, certificado, cola, almacenamiento, integración y seguridad.

12. Observabilidad

- Logs JSON con timestamp, level, service, tenant, company, user, request_id y event_id; sin secretos.
- Métricas de latencia, errores, colas, DB, locks, emisión, pagos, inventario y documentos.
- Trazas distribuidas para API, workers e integraciones.
- Alertas por numeración, fallos fiscales, diferencias, permisos vencidos, backups y seguridad.
- Dashboards técnicos y de negocio diferenciados.
- Retención y acceso a logs bajo permisos y política.

13. Operación y soporte

Nivel	Alcance
L1	Acceso, navegación, uso funcional, incidentes conocidos y recopilación de evidencia.
L2	Configuración, datos, procesos, integración y resolución operativa.
L3	Desarrollo, base de datos, rendimiento, seguridad y defectos complejos.
Fiscal/legal	Interpretación, reglas, homologación y cambios normativos.
Infraestructura	Disponibilidad, red, contenedores, backups, certificados y recuperación.

Fuentes, criterio de prevalencia y control de vigencia

Las fuentes oficiales y las Gacetas Oficiales prevalecen sobre manuales comerciales, documentación histórica, comportamiento actual del código o prácticas de mercado. Saint se usa como referencia comparativa, no como autoridad legal. Antes de producción, la matriz normativa debe ser revisada por abogado tributario venezolano, contador público y equipo de homologación.

Ref.	Fuente	Uso
F1	Documento Maestro de Requerimientos de INNOVA v1.1	Línea base funcional, fiscal, técnica, flujos, máquinas de estado, wireframes y criterios de prueba suministrados por el usuario.
F2	Manual Saint Enterprise Administrativo	Referencia comparativa de maestros, transacciones, configuración, usuarios, roles, ventas, compras, bancos y operaciones de inventario; no constituye fuente legal.
F3	Compilación de Providencias Administrativas SENIAT	Incluye SNAT/2011/00071, SNAT/2018/0141, SNAT/2024/000102, SNAT/2024/000121, SNAT/2025/000054, providencias IGTF y calendario fiscal 2026.
F4	Expediente normativo SICA, SIGESAI y Decreto N.º 1.808	Base funcional para retenciones ISLR, control agroalimentario, movilización, permisos y bloqueos regulatorios.
F5	Documento INNOVA - Guías SENIAT, SICA y SIGESAI	Diferenciación de documentos fiscales, guías SUNAGRO y permisos INSAI; reglas de validación

Ref.	Fuente	Uso
		y auditoría.
F6	Ley del IVA - G.O. N.º 6.507 Extraordinario	Texto legal principal publicado por la Asamblea Nacional.
F7	Ley de ISLR - G.O. N.º 6.210 Extraordinario	Texto legal principal publicado por la Asamblea Nacional.
F8	Ley de Reforma del IGTF - G.O. N.º 6.687 Extraordinario	Texto legal principal publicado por la Asamblea Nacional.
F9	Código Orgánico Tributario - G.O. N.º 6.507 Extraordinario	Marco general de deberes formales, fiscalización, responsabilidad, conservación e ilícitos.
F10	INSAI - Manuales oficiales SIGESAI	Manuales de registro, movilización, certificados y trámites publicados por el INSAI.

Fuentes oficiales en línea consultadas: Ley del IVA - Asamblea Nacional | Ley de ISLR | Ley IGTF | SIGESAI | Manuales INSAI